

Ứng dụng Ghi chú Bảo mật

An toàn và Bảo mật trong Phát triển Phần mềm Di động

Nhóm 10

- Nguyễn Hữu Phước – CT050439
- Trần Văn Hiệp – CT050415
- Nguyễn Năng Minh – CT060426

Giảng viên: TS. Thái Thị Thanh Vân

Tổng quan

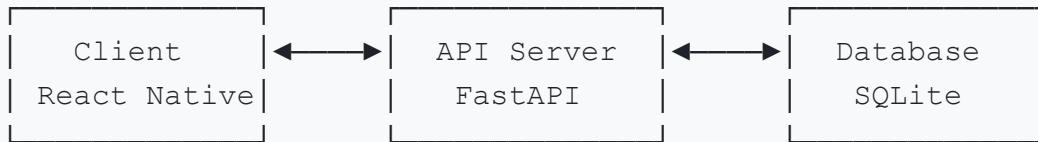
Ứng dụng ghi chú bảo mật cho di động

-  7 cơ chế bảo mật đã triển khai
-  Mã hóa dữ liệu **end-to-end**
-  Xác thực đa yếu tố
-  Quản lý ghi chú và công việc

Hôm nay chúng em sẽ demo từng cơ chế bảo mật

Demo - App Overview

Kiến trúc hệ thống



Đặc điểm:

- Tất cả dữ liệu được **mã hóa** trước khi lưu
- Mỗi user có **khóa mã hóa riêng**
- API có **rate limiting** và **security headers**

Cơ chế 1: Password Hashing + JWT

Demo: Đăng ký → Đăng nhập

Password Hashing:

```
hashed_password = hash_password(password)
```

JWT:

```
access_token = create_access_token(user_id)  
refresh_token = create_refresh_token(user_id)
```

Kết quả:

-  Mật khẩu hash (bcrypt)
-  Token authentication
-  Refresh token rotation

Cơ chế 2: AES-256-GCM Encryption

Demo: Tạo ghi chú → Database

Trước: Plaintext

```
Title: "Ghi chú bí mật"
```

Sau: Ciphertext trong DB

```
title_encrypted: "gAAAAABl..."  
content_encrypted: "gAAAAABm..."
```

Code:

```
encrypted = encrypt_note_data(plaintext, key)
```

✓ Mã hóa tự động khi lưu, giải mã khi xem

Cơ chế 3: TOTP/2FA

Demo: Setup → Login

Setup:

- Generate secret → QR code
- Quét bằng Authenticator app

Login:

- Password → Mã 2FA (6 số)
- Verify từ Authenticator

Code:

```
secret = generate_totp_secret()  
verify_totp_code(code, secret)
```

✓ Bảo vệ với 2 yếu tố

Cơ chế 4: Biometric Authentication

Demo: Vân tay/Face ID

Quy trình:

1. Enable trong Settings
2. Đăng nhập → Chọn Biometric
3. Xác thực vân tay/Face ID
4. Gửi backup code đến server

Ưu điểm:

-  Tiện lợi, nhanh chóng
-  An toàn (backup code mã hóa)

Cơ chế 5: Rate Limiting

Demo: Đăng nhập sai nhiều lần

Giới hạn:

- Login: 5 lần/phút
- Register: 3 lần/giờ

Code:

```
@limiter.limit("5/minute")  
async def login(...):
```

Response:

```
429 Too Many Requests  
Rate limit exceeded
```

✅ Chống brute force & spam

Cơ chế 6: Security Headers

Demo: DevTools → Network

Headers:

```
X-Content-Type-Options: nosniff  
X-Frame-Options: DENY  
X-XSS-Protection: 1; mode=block
```

Code:

```
response.headers["X-Content-Type-Options"] = "nosniff"  
response.headers["X-Frame-Options"] = "DENY"  
response.headers["X-XSS-Protection"] = "1; mode=block"
```

✓ Bảo vệ: XSS, clickjacking, MIME sniffing

Demo: Chia sẻ ghi chú

Mã hóa lại bằng key người nhận

Quy trình:

1. User A chia sẻ với User B
2. Giải mã bằng key User A
3. Mã hóa lại bằng key User B
4. Tạo bản sao trong DB

Kết quả:

- 2 bản ghi (owner + recipient)
- Mỗi bản mã hóa khác nhau
- User chỉ giải mã được của mình
- ✓ Mỗi user có key riêng

Tổng hợp 7 cơ chế bảo mật

#	Cơ chế	Mục đích
1	Password Hashing (bcrypt)	Bảo vệ mật khẩu
2	JWT Authentication	Xác thực người dùng
3	AES-256-GCM Encryption	Mã hóa dữ liệu
4	TOTP/2FA	Xác thực hai yếu tố
5	Biometric Auth	Đăng nhập sinh trắc học
6	Rate Limiting	Chống brute force
7	Security Headers	Bảo vệ web attacks

Defense in Depth

5 lớp bảo mật

Lớp 1: Network Security
(HTTPS, Security Headers)

Lớp 2: Authentication
(JWT, 2FA, Biometric)

Lớp 3: Authorization
(Token validation)

Lớp 4: Data Encryption
(AES-256-GCM)

Lớp 5: Rate Limiting
(Chống brute force)

Nguyên tắc: Nhiều lớp bảo vệ = An toàn hơn

Kết quả & Kết luận

Đã đạt được

- 7 cơ chế bảo mật triển khai thành công
- Demo hoạt động tốt
- Tuân thủ **best practices**
- Ứng dụng thực tế

Thống kê

- **Coverage:** Auth, Encryption, Authorization, Rate Limiting
- **Compliance:** OWASP Top 10
- **Code Quality:** Clean, documented

Cảm ơn!

Xin mời câu hỏi

Liên hệ:

- GitHub: [repo link]
- Email: [nhóm email]